

DET-009 | New Local Administrator Account Created

ID: DET-009

MITRE ID: T1136.001

Data Source: Security Event

Severity: High

Tactic: Persistence

Category: PRIVILEGE ESCALATION

ADX MAPPING LOGIC:

Mapping: EventId (4720=AccountCreate, 4732=GroupAdd) → we simulate using EventType pairs. Source = 'SubjectAccount', State = 'Computer'. We use set_has_element() and make_set() to detect both events occurring for the same 'target' in a window.

OBJECTIVE: Practice make_set() and set_has_element() — operators used to detect event pairs (account creation + admin group add). Real Sentinel uses SecurityEvent EventID 4720 + 4732 correlation.

KQL QUERY (RUNNABLE ON ADX FREE TIER)

StormEvents

| where StartTime > ago(365d)

| extend SimEventId = case(

EventType in ("Tornado","Hurricane"), "4720", // Account created

EventType in ("Flash Flood","Coastal Flood"), "4732", // Added to admin group

"OTHER")

| where SimEventId in ("4720","4732")

| summarize

EventIds = make_set(SimEventId),

SubjectAcct = any(Source),

EventTypes = make_set(EventType, 4),

FirstSeen = min(StartTime),

LastSeen = max(StartTime),

EventCount = count()

by State, EpisodeId

| where set_has_element(EventIds, "4720")

and set_has_element(EventIds, "4732") // BOTH events for same target

| project Computer = State, TargetAcct = tostring(EpisodeId), SubjectAcct,

EventIds, EventCount, FirstSeen, LastSeen

| order by FirstSeen desc

| take 20

INVESTIGATION STEPS

1. Verify if SubjectAccount is an authorised admin or IT account.
2. Check if account creation was part of a change ticket (ServiceNow).
3. Review all actions performed by the new account after creation.
4. Check for signs of lateral movement from the same device.

RESPONSE ACTIONS

- Disable the newly created account immediately.
- Remove from local Administrators group.
- Review the creating account for compromise.
- Escalate to Tier 2 if no change ticket found.

Output from Above KQL Query:

```
1 StormEvents
2 | where StartTime > ago(365d)
3 | extend SimEventId = case(
4 EventType in ("Tornado","Hurricane"), "4720",
5 EventType in ("Flash Flood","Coastal Flood"), "4732", "OTHER")
6 | where SimEventId in ("4720","4732")
7 | summarize
8 EventIds = make_set(SimEventId),
9 SubjectAcct = any(Source),
10 EventTypes = make_set(EventType, 4),
11 FirstSeen = min(StartTime),
12 LastSeen = max(StartTime),
13 EventCount = count()
14 by State, EpisodeId
15 | where set_has_element(EventIds, "4720")
16 and set_has_element(EventIds, "4732") // BOTH events for same target
17 | project Computer = State, TargetAcct = tostring(EpisodeId), SubjectAcct,
18 EventIds, EventCount, FirstSeen, LastSeen
19 | order by FirstSeen desc
20 | take 20
```

Table 1 + Add visual Stats 2

Computer	TargetAcct	SubjectAcct	EventIds	EventCount	FirstSeen	LastSeen
----------	------------	-------------	----------	------------	-----------	----------

No Rows To Show

KQL Detection Query in Sentinel:

SecurityEvent

| where TimeGenerated > ago(1h)

| where EventID in (4720, 4732)

| extend AccountCreated = iff(EventID == 4720, TargetAccount, ""),

GroupMembership = iff(EventID == 4732, TargetAccount, "")

| summarize

Events = make_set(EventID),

SubjectAcct = any(SubjectAccount),

TargetAcct = any(TargetAccount),

FirstSeen = min(TimeGenerated),

LastSeen = max(TimeGenerated)

by Computer, TargetAccount

| where set_has_element(Events, 4720) and set_has_element(Events, 4732)

| project Computer, TargetAcct, SubjectAcct,

Events, FirstSeen, LastSeen

| order by FirstSeen desc